

SIMATS ENGINEERING

ASSESSMENT TOOL 1

Name	Abinеш M
Register Number	192465050
Date	
Time	1 Hr

COURSE NAME: Cybersecurity Incident Handling And Response

COURSE CODE: CSA6001

COURSE OUTCOME COVERED

C05: *Implement database operations using query processing, optimization, and transaction management to ensure consistency and reliability. (BL3, BL4)*

Activity Tool : Constraint-Based Problem Solving (High)

Assessment Tool Weightage:40%

Code of Conduct:

I Abinеш M 192465050 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Abinеш M

192465050

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Post-Incident Review and Timeline Reconstruction	25%	Thoroughly reconstructs the incident timeline using relevant logs, alerts, tickets, and evidence and clearly identifies key events and response actions.	Reconstructs the major incident timeline and identifies key events with minor omissions.	Provides a basic timeline but misses important events or sequence details.	Unable to reconstruct the incident timeline accurately.
Root Cause Analysis and Contributing Factors	25%	Accurately identifies the root cause, contributing factors, security weaknesses, and underlying issues using strong evidence and logical analysis.	Identifies the main root cause and contributing factors with minor gaps in analysis.	Identifies a probable cause but provides limited analysis of contributing factors.	Unable to identify the root cause or supporting factors.
Lessons Learned and Impact Assessment	20%	Clearly evaluates what worked and failed during the incident, assesses technical and business impact, and derives meaningful lessons learned.	Provides a reasonable assessment of impact and lessons learned with minor omissions.	Provides basic lessons learned and limited impact assessment.	Fails to identify meaningful lessons learned or assess the incident impact.
Recommendations and Future Prevention	15%	Provides specific, practical, and prioritized recommendations covering security controls, policies, processes, monitoring, and prevention of recurrence.	Provides relevant recommendations with minor gaps in prioritization or implementation details.	Provides general recommendations with limited connection to identified weaknesses.	Provides few or inappropriate recommendations for future prevention.
Documentation, Final Report, and Presentation	15%	Provides a clear, professional final report with evidence, findings, timeline, root cause, lessons learned, recommendations, and well-structured presentation.	Report is well organized and contains most required findings with minor presentation issues.	Report is partially organized with limited evidence, analysis, or supporting details.	Report is incomplete, poorly organized, and lacks clear findings or supporting evidence.

Root Cause Analysis and Incident Reporting

Question 1: Root Cause Analysis

A malware incident triggered by an employee opening a malicious email attachment appears, on the surface, to be a simple case of human error. However, a proper root cause analysis (RCA) looks beyond the immediate trigger to understand why the organization's defenses did not prevent, detect, or contain the resulting infection. As a cybersecurity consultant, I approach this using a layered analysis — separating the immediate cause from the contributing factors and the deeper systemic weaknesses — so that corrective action addresses the whole chain, not just the last link.

1. Immediate Cause

The immediate (proximate) cause is the direct trigger of the incident: an employee opened a malicious attachment delivered via email, executing the embedded malware on their workstation. This is the action that started the incident timeline, but treating it in isolation would lead to an incomplete and ultimately ineffective response — organizations that stop here typically respond only with employee discipline or generic awareness training, without addressing why the email reached the inbox or why execution succeeded unimpeded.

2. Contributing Factors

- **Outdated software:** Investigation indicates the workstation was running outdated software with known, unpatched vulnerabilities, which allowed the malware to execute successfully and escalate privileges or persist in ways a patched system would have blocked or contained.
- **Weak security controls:** Insufficient email filtering allowed the malicious attachment to reach the employee's inbox in the first place, and inadequate endpoint protection (outdated antivirus signatures, no application allow-listing, no EDR behavioral detection) failed to catch the malware at execution time.
- **Limited security awareness:** The employee's decision to open the attachment suggests gaps in phishing-recognition training or an absence of a clear, low-friction process for reporting suspicious emails before opening them.
- **Insufficient network segmentation:** If the malware was able to spread or communicate outward without early detection, this points to a contributing lack of network segmentation or monitoring that should have limited its blast radius.

3. Underlying (Root) Weaknesses

Beneath the contributing factors lie systemic organizational weaknesses — the true root causes that, if left unaddressed, will produce similar incidents again with a different trigger:

- Absence of a formal, enforced patch-management program, leaving software updates to chance rather than a scheduled, auditable process.
- No layered (defense-in-depth) security architecture — the organization relied on a small number of controls (e.g., basic antivirus) rather than combining email

filtering, endpoint detection, network segmentation, and user training as overlapping safeguards.

- Security awareness treated as a one-time or infrequent activity rather than an ongoing program with simulated phishing exercises and measurable improvement over time.
- Lack of a security governance function with the authority and budget to enforce patching SLAs, evaluate control effectiveness, and hold system owners accountable for outdated software.

4. Applying the '5 Whys' Technique

Why #	Question and Answer
1	Why did the malware infect the system? — The employee opened a malicious attachment.
2	Why did opening it lead to infection? — The workstation ran outdated, vulnerable software the malware could exploit.
3	Why was the software outdated? — No enforced patch-management process was in place.
4	Why was there no enforced process? — No governance function owned patch compliance across the organization.
5	Why was there no governance function? — Security was under-resourced and not prioritized at a leadership/budget level.

This technique illustrates how a seemingly simple human-error incident traces back to an organizational resourcing and governance gap — the true root cause that corrective actions must ultimately address.

5. Recommended Corrective Actions

Weakness Addressed	Corrective Action	Expected Outcome
Outdated software	Implement a formal, SLA-driven patch-management program with regular compliance audits	Known vulnerabilities closed within a defined window, reducing exploitability
Weak email/endpoint controls	Deploy advanced email filtering (sandboxing attachments) and EDR with behavioral detection	Malicious attachments blocked or detected before/at execution
Awareness gaps	Ongoing phishing-simulation training with	Reduced click-through rate on phishing attempts over time

Weakness Addressed	Corrective Action	Expected Outcome
	metrics tracked per department	
Lack of governance	Establish a security governance function with executive sponsorship and defined accountability	Sustained investment and enforcement of security controls over time

6. RCA Methodology Summary

- **Fishbone (Ishikawa) categorization:** Beyond the linear 5-Whys, contributing factors can be grouped into standard categories — People (awareness gaps), Process (no patch-management SLA), Technology (outdated software, weak filtering), and Governance (lack of security ownership) — helping ensure no category of weakness is overlooked.
- **Evidence-based, not blame-based:** Throughout the RCA, findings are tied to specific log evidence, patch records, and control configurations rather than assumptions, and the analysis deliberately avoids framing the employee as the 'cause' in isolation, since doing so discourages future reporting of suspicious activity.
- **Validation with stakeholders:** Draft RCA findings are reviewed with IT, security, and business stakeholders before finalization, ensuring contributing factors and root causes are accurate and that proposed corrective actions are operationally realistic.

7. Classifying Corrective Actions by Control Type

Recommended corrective actions are further classified by control type, which helps ensure the response includes not just one layer of defense but a balanced mix that both reduces the likelihood of recurrence and limits impact if prevention fails:

Control Type	Purpose	Example From This Incident
Preventive	Stops the incident from occurring in the first place	Patch management, email attachment sandboxing
Detective	Identifies the incident quickly if prevention fails	EDR behavioral detection, network monitoring
Corrective	Limits damage and restores normal operations	Incident response playbooks, validated backups
Administrative	Governs people and process to sustain the other controls	Security governance function, patch SLAs, training program

Mapping recommendations to control type also helps leadership see whether the proposed remediation plan is balanced or over-weighted toward one layer (for example, addressing only prevention while leaving detection and governance gaps unaddressed) before it is approved and funded.

Question 2: Incident Documentation and Final Reporting

Following a serious cybersecurity incident, management needs a clear, complete, and well-organized final report — both to understand what happened and to satisfy potential regulatory, legal, insurance, and board-level reporting obligations. As the consultant preparing this report, I structure it around a consistent set of sections so that both technical and non-technical stakeholders can find the information relevant to them.

1. Executive Summary / Incident Summary

A brief, non-technical overview at the top of the report covering what happened, when it was detected, the overall impact, and the current status (contained, resolved, under ongoing monitoring). This section is written for executives and board members who need the key facts without technical detail, with the full narrative and evidence available in the sections that follow.

2. Timeline of Events

- **Chronological reconstruction:** A detailed, timestamped sequence from initial compromise through detection, containment, eradication, and recovery, built from log evidence rather than assumption.
- **Key milestones highlighted:** Clearly mark when the incident began, when it was detected, when containment was achieved, and when normal operations resumed, since these intervals (time-to-detect, time-to-contain) are often tracked as key metrics.
- **Source attribution:** Each timeline entry references the specific log or evidence source it is drawn from, supporting traceability and any later legal or regulatory review.

3. Affected Assets and Scope

- A complete inventory of affected systems, accounts, and data, including criticality classification for each (as established in recovery planning).
- Clear statement of what was NOT affected, where confirmable, to accurately scope the incident and avoid over- or under-stating impact.
- Any third parties, customers, or partners whose data or systems were impacted, relevant to notification obligations.

4. Root Cause

A concise statement of the immediate cause, contributing factors, and underlying weaknesses — following the same layered RCA structure outlined in Question 1 — giving readers a clear understanding of not just what happened, but why the organization's defenses did not prevent it.

5. Impact Assessment

Impact Category	What to Document
Operational	Downtime duration, affected business processes, productivity loss
Financial	Direct incident-response costs, potential regulatory fines, business disruption cost
Data	Type and volume of data affected, confirmed vs. suspected exposure
Reputational/Compliance	Customer notification requirements, regulatory reporting obligations triggered

6. Response Actions Taken

A structured account of the response, typically organized around the standard incident-response phases — detection, containment, eradication, and recovery — describing specifically what actions were taken at each phase, by whom, and when, giving stakeholders confidence that the response followed a disciplined, professional process rather than an ad hoc reaction.

7. Evidence and Supporting Documentation

- A catalog of preserved evidence — logs, forensic images, malware samples, screenshots — with clear chain-of-custody documentation for anything that may support legal, insurance, or law-enforcement processes.
- References to specific evidence items throughout the timeline and root-cause sections, so claims in the report are traceable back to supporting artifacts rather than presented as unsupported assertions.
- Any external analysis (e.g., third-party forensic firm findings, malware sandbox reports) attached or referenced as appendices.

8. Lessons Learned

An honest assessment of what worked well during the response and what did not — covering detection speed, communication effectiveness, tooling gaps, and any process breakdowns — gathered through a structured post-incident review meeting with all responding teams while the details are still fresh.

9. Recommendations for Future Prevention

Concrete, prioritized recommendations tied directly to the root causes identified — mirroring the corrective-action structure from Question 1 — each with an owner, target timeline, and a way to measure completion, so the report drives real organizational change rather than sitting unread after the incident is closed.

10. Report Distribution and Handling

Finally, the report itself is classified and distributed appropriately — typically restricted to executive leadership, legal counsel, and relevant regulators, with a redacted or

summarized version prepared separately if wider internal or public communication is required. Given the sensitivity of incident details, the report should be marked confidential and access-controlled like any other sensitive business document.

11. Report Structure at a Glance

For ease of reference, the full report typically follows this section order, allowing different audiences to navigate directly to what's relevant to them:

Section	Primary Audience	Purpose
1	Executives, board	Executive summary — what happened and current status, in plain language
2–3	IT, security team	Timeline and affected assets — technical detail of scope and sequence
4–6	Security, risk, legal	Root cause and impact — why it happened and what it cost
7	Legal, forensics, auditors	Evidence — supporting documentation and chain of custody
8–9	Security leadership, IT management	Lessons learned and recommendations — the forward-looking action plan

Organizing the report this way ensures each stakeholder group can quickly locate the sections most relevant to their role, while the complete document still stands as a single, coherent, evidence-based account of the incident from start to finish.

12. Report Quality Checklist

Before final submission, the report is reviewed against a short quality checklist to confirm it will hold up to executive, legal, and — where applicable — regulatory scrutiny:

- Every factual claim in the timeline and root-cause sections is traceable to a specific piece of evidence, not stated as an assumption.
- Technical terms are explained or accompanied by plain-language summaries so executive and board readers are not left guessing at meaning.
- Recommendations are specific and assigned an owner and target date, rather than generic statements like 'improve security awareness.'
- The report has been reviewed by legal counsel where regulatory notification or litigation risk is present, before wider distribution.
- Sensitive details (e.g., specific exploited vulnerabilities still being remediated elsewhere) are appropriately restricted in any broadly distributed version.

Conclusion

Both tasks reflect the same underlying discipline: looking past the surface-level event to build a complete, evidence-based picture. A root cause analysis that stops at 'an employee clicked a link' misses the outdated software, weak controls, and governance gaps that turned a single click into a full incident — just as a final report that lists only

what happened, without root cause and actionable recommendations, fails to help the organization actually prevent a recurrence. Thorough root cause analysis and disciplined incident reporting together turn a costly security event into a concrete, prioritized roadmap for a stronger security posture going forward.